TRACE-WAF: Khung đánh giá ba trục và quản trị luật WAF có truy vết CWE/CVE

[Họ và tên tác giả]

[Đơn vị đào tạo / khoa / trường]

[Email liên hệ]

Bài nghiên cứu học phần Chính sách và quản trị an ninh mạng

Tóm tắt. Tường lửa ứng dụng web (Web Application Firewall, WAF) cung cấp một lớp phòng thủ trước SQL injection (SQLi), cross-site scripting (XSS) và path traversal. Tuy nhiên, hiệu năng phòng thủ không thể kết luận chỉ từ số mẫu tấn công bị chặn: các biến đổi biểu diễn đầu vào có thể làm giảm khả năng phát hiện, trong khi luật quá rộng có thể chặn lưu lượng hợp lệ. Nghiên cứu này đề xuất **TRACE-WAF**, một khung quản trị và đánh giá luật WAF theo ba trục **attack coverage, false-positive rate (FPR) và evasion robustness**, gắn với hồ sơ nguồn bằng chứng CWE/CVE và quy trình phê duyệt–theo dõi–rollback. Để kiểm tra tính khả thi của phần đánh giá, nghiên cứu xây dựng một benchmark ngoại tuyến có thể tái lập, gồm 450 mẫu có dấu hiệu tấn công và 120 mẫu hợp lệ trên tập kiểm thử, với ba nhóm CWE-89, CWE-79 và CWE-22. Ba bộ phát hiện quy tắc mô phỏng được so sánh: nhận diện chữ ký thô, chữ ký sau chuẩn hóa và luật có ngữ cảnh tuyến xử lý. Kết quả tương ứng là coverage **50,67% / 93,33% / 100,00%**; FPR **50,00% / 50,00% / 16,67%**; robustness trên biến thể **38,33% / 91,67% / 100,00%**. Mặc dù nguyên mẫu có ngữ cảnh nhận diện toàn bộ mẫu tấn công trong tập thử nghiệm, **nó không đạt ngưỡng FPR 5% được đề xuất cho cổng phê duyệt**. Kết quả chỉ chứng minh khả năng vận hành của phương pháp đo trên dữ liệu tổng hợp, **không** chứng minh hiệu quả với WAF thương mại, CVE thực, hay hệ thống sinh luật bằng LLM. Đóng góp chính là một giao thức đo có truy vết, dữ liệu và mã có thể chạy lại, đồng thời nhấn mạnh vai trò kiểm soát thay đổi trong quản trị an ninh mạng.

Từ khóa: WAF; CWE; CVE; SQL injection; XSS; path traversal; false positive; evasion robustness; LLM; quản trị thay đổi.

1. Giới thiệu

1.1. Bối cảnh và động cơ

WAF kiểm tra yêu cầu HTTP ở lớp ứng dụng và thường áp dụng các tập luật chữ ký, quy tắc hành vi hoặc mô hình bất thường. OWASP Core Rule Set (CRS) là một nền tảng tham chiếu quan trọng, hỗ trợ phát hiện những nhóm tấn công phổ biến và đồng thời đặt mục tiêu giảm cảnh báo sai [1]. Tuy vậy, một WAF chỉ là lớp phòng thủ bổ sung: khả năng bảo vệ chịu ảnh hưởng của đường đi ứng dụng, cách xử lý tham số, chuẩn hóa chuỗi, cấu hình luật và cơ chế xử lý ở backend [1], [2].

Trong báo cáo công bố ngày 17/12/2025, Miggo cho biết 52% các trường hợp khai thác

trong mẫu hơn 360 CVE mà đơn vị khảo sát vượt qua bộ luật WAF mặc định, theo điều kiện đánh giá của họ [3]. Đây là **kết quả do nhà cung cấp công bố trên tập dữ liệu lựa chọn**, không phải ước lượng phổ quát cho tất cả WAF hoặc tất cả CVE. Công bố DEG-WAF của Trần Gia Bảo và cộng sự mô tả việc kết hợp mô hình ngôn ngữ, lấy mẫu theo ngữ pháp và học tăng cường để sinh biến thể đánh giá WAF [4]. Nghiên cứu GenSQLi sử dụng LLM để tạo và xác minh các mẫu SQLi, sau đó tổng hợp luật phòng thủ [5]. Những công trình này thúc đẩy hướng nghiên cứu hai chiều: **sinh trường hợp kiểm thử và đề xuất biện pháp phòng thủ**.

Vấn đề quản trị xuất hiện khi đánh giá chỉ công bố một tỷ lệ chặn hoặc tỷ lệ bypass. Tăng độ nhạy có thể dẫn đến chặn nhầm người dùng hợp lệ; thêm luật mà thiếu nguồn truy vết, phân công chủ sở hữu và cơ chế rollback có thể tạo rủi ro vận hành. Do đó nghiên cứu đặt trọng tâm vào một giao thức đánh giá và phê duyệt có thể kiểm toán.

1.2. Bài toán nghiên cứu

Cho một tập trường hợp đầu vào có nhãn, một cơ chế biến đổi biểu diễn và một tập luật WAF, cần xác định **cùng lúc** mức bao phủ tấn công, chi phí chặn nhầm và tính bền vững khi đầu vào được biểu diễn khác đi. Quyết định chấp nhận luật không dựa vào một chỉ số đơn lẻ mà là bộ điều kiện đồng thời, có nguồn bằng chứng, chủ sở hữu và vòng đời thay đổi.

Ba câu hỏi nghiên cứu được đặt ra:

- **RQ1:** Ba chỉ số coverage, FPR và robustness có thể được đặc tả thành quy trình benchmark tái lập và diễn giải được hay không?
- **RQ2:** Trong môi trường mô phỏng, chuẩn hóa đầu vào và phân luồng chính sách có ảnh hưởng như thế nào đến từng trục đánh giá?
- **RQ3:** Cần những thành phần quản trị nào để chuyển từ luật ứng viên, kể cả luật do LLM đề xuất, sang quyết định cho phép thử nghiệm hoặc triển khai?

1.3. Phạm vi và đóng góp

Nghiên cứu giới hạn vào các dấu hiệu của **CWE-89** (SQL injection), **CWE-79** (XSS) và **CWE-22** (path traversal) theo định nghĩa MITRE [6]–[8]. Phần mã nguồn là một nguyên mẫu **ngoại tuyến**, không gửi yêu cầu đến website hoặc WAF thực, không thực thi nội dung tấn công và không truy vấn LLM. Vì thế, kết quả mô phỏng không được diễn giải là số liệu triển khai sản xuất.

Các đóng góp ở mức bài tập gồm: (i) định nghĩa và quy trình tính toán ba trục đánh giá; (ii) dữ liệu tổng hợp với nhãn, nhóm biến đổi, tuyến ứng dụng và tập giữ lại; (iii) nguyên mẫu ba chính sách để chứng minh trade-off; (iv) sổ đăng ký rule có CWE, chứng cứ, phạm vi, chủ sở hữu, trạng thái và rollback; (v) lộ trình kiểm định LLM trong giai đoạn mở rộng mà không ngộ nhận đã thử nghiệm LLM.

2. Cơ sở lý thuyết và nghiên cứu liên quan

2.1. CWE, CVE và phạm vi phát hiện WAF

CWE là hệ phân loại **loại điểm yếu**, trong khi CVE định danh một lỗ hổng được công bố trên sản phẩm hoặc thành phần cụ thể. CWE-89 mô tả xử lý không an toàn các ký tự điều khiển trong câu lệnh SQL; CWE-79 liên quan đến dữ liệu không được trung hòa đúng cách khi tạo trang web; CWE-22 mô tả đường dẫn không được giới hạn đúng trong vùng cho phép [6]–[8]. Việc một rule gắn CWE không đồng nghĩa rule bảo vệ được mọi CVE có cùng CWE. Muốn khẳng định bảo vệ CVE, phải có phiên bản ứng dụng, điểm vào, điều kiện kích hoạt và phép thử trên hệ thống có thể tái tạo.

2.2. Công trình liên quan và khoảng trống thực hành

DEG-WAF sử dụng OPT-125M, mô hình phần thưởng, sinh theo ngữ pháp và tác tử học tăng cường PPO/A2C nhằm khám phá biến thể vượt WAF; các con số bypass công bố phụ thuộc WAF, loại tấn công và thiết lập thử nghiệm [4]. **GenSQLi** kết hợp sinh payload, xác thực với ứng dụng có lỗ hổng và tạo luật; công bố cho biết 514 payload SQLi mới được sinh và 23 luật mới chặn 99% các trường hợp tấn công từng vượt qua WAF trong môi trường nghiên cứu đó [5]. Các kết quả này có ý nghĩa về phương pháp, nhưng **không so sánh trực tiếp** được với số liệu trong bài này vì đối tượng, nhãn, môi trường và mẫu đánh giá khác nhau.

OWASP CRS nêu rõ mối quan hệ giữa ngưỡng anomaly score, paranoia level và false positive. Gia tăng mức phát hiện thường đòi hỏi loại trừ luật hoặc điều chỉnh theo ứng dụng để tránh chặn nhầm [2]. Trong nhóm tài liệu được khảo sát, nghiên cứu này tập trung bổ sung một **giao thức kiểm thử thống nhất ở mức bài tập** kết hợp ba chỉ số với bằng chứng và quy trình phê duyệt; **không tuyên bố** đây là tiêu chuẩn đầu tiên hay rằng cộng đồng chưa có benchmark liên quan.

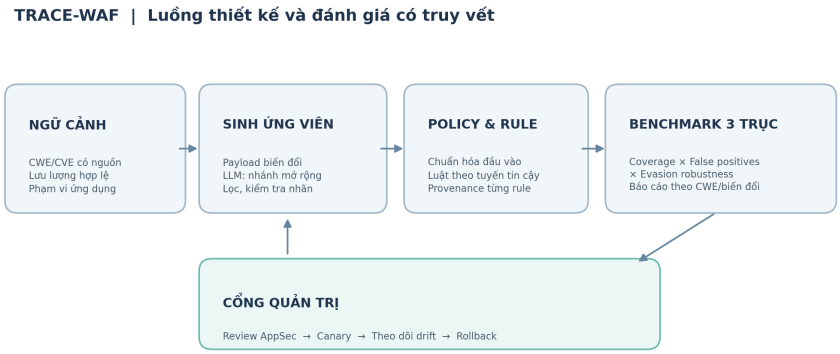
Bảng 1. Tổng hợp nghiên cứu liên quan và ranh giới đánh giá

Công trình / nguồn	Trọng tâm chính	Giá trị tham chiếu	Ranh giới so với bài này
OWASP CRS [1], [2]	Tập luật, anomaly scoring, tuning FPR	Thực tiễn WAF và chi phí cảnh báo sai	Không phải bộ thí nghiệm đã chạy trong bài
DEG-WAF [4]	LLM + RL để sinh biến thể	Tư duy kiểm thử dưới biến đổi né tránh	Không tái hiện RL/LLM hoặc đo bypass thực
GenSQLi [5]	LLM sinh SQLi và xây dựng luật	Kiến trúc kiểm thử hai chiều	Không tái hiện GPT-4o/ModSecurity
Miggo [3]	So sánh trên tập CVE do nhà cung cấp công bố	Động cơ về giới hạn luật mặc định	Không dùng tỷ lệ 52% làm baseline thực nghiệm

Công trình / nguồn	Trọng tâm chính	Giá trị tham chiếu	Ranh giới so với bài này
TRACE-WAF (bài này)	Ba trục + truy vết + change control	Giao thức đo và demo tái lập	Chỉ có ba classifier mô phỏng, dữ liệu tổng hợp

3. Thiết kế TRACE-WAF

3.1. Kiến trúc đề xuất



Hình 1: Kiến trúc TRACE-WAF: bối cảnh và chứng cứ, sinh ứng viên, chính sách phát hiện, benchmark ba trục và cổng quản trị.

Kiến trúc phân tách **nguồn bằng chứng**, **trường hợp kiểm thử**, **chính sách phát hiện** và **quyết định triển khai**. Sổ đăng ký chứng cứ lưu `rule_id`, CWE, liên kết CVE nếu đã xác minh, version rule, tuyến áp dụng, nguồn mẫu, chủ sở hữu và phương án rollback. Nguồn có thể là MITRE CWE, cơ sở CVE chính thức, hồ sơ lỗi ứng dụng hoặc log đã được xử lý riêng tư. Dữ liệu đầu vào cần phân loại mức tin cậy và hạn chế thông tin nhận dạng.

Ở nhánh mở rộng, LLM có thể đề xuất biến thể có cấu trúc theo CWE hoặc đề xuất điều kiện phát hiện và giải thích; tuy nhiên đầu ra của LLM là **ứng viên chưa đáng tin cậy**, phải đi qua kiểm tra cú pháp, khử trùng lặp, kiểm tra bảo toàn ý nghĩa, đánh giá false positive và phê duyệt bởi người chịu trách nhiệm. Trong mã thực nghiệm hiện tại, nhánh này được thay bằng **biến đổi xác định theo mẫu** và ba classifier thủ công. Đây là phân biệt bắt buộc giữa **kiến trúc mục tiêu** và **chức năng đã chứng minh**.

3.2. Chuẩn hóa biểu diễn và ngữ cảnh

Ba mức chính sách trong nguyên mẫu là:

1. **Raw signature:** so khớp các dấu hiệu SQLi, XSS và dấu `../` hoặc `..\` ngay trên chuỗi đầu vào.

2. **Canonical signature:** chuẩn hóa có giới hạn qua URL decoding và HTML entity decoding tối đa ba vòng rồi áp dụng cùng tập chữ ký.
3. **TRACE-Policy:** chuẩn hóa như mức 2; xử lý khoảng trắng và comment mô phỏng trong SQL; giới hạn rule theo tuyến xử lý được proxy tin cậy cung cấp; với đường dẫn, đánh giá xem chuỗi có thoát gốc tài liệu mô phỏng hay không.

Giới hạn ba vòng chuẩn hóa là quyết định kỹ thuật của nguyên mẫu, **không** đảm bảo phù hợp cho mọi ứng dụng. Đầu vào đã giải mã phải được đối chiếu với đúng thứ tự biến đổi của framework và máy chủ thật; ngược lại WAF và backend có thể nhìn thấy các chuỗi khác nhau. Quy tắc cho `/api/tutorial` giả định tầng ứng dụng xuất mã HTML đã escape; giả định này **chưa được kiểm tra bằng backend thật** và không phải giấy phép miễn trừ chung đối với XSS.

3.3. Định nghĩa bộ ba chỉ số

Xét tập kiểm thử $D = A \cup B$ với A gồm các chuỗi có dấu hiệu tấn công và B gồm các chuỗi được gắn nhãn hợp lệ. Gọi $f(r) \in \{0, 1\}$ là quyết định cho phép (0) hoặc chặn (1). Mô hình báo cáo các chỉ số sau:

$$\text{Coverage} = \frac{TP}{TP + FN}, \qquad \text{FPR} = \frac{FP}{FP + TN}.$$

Gọi A_{trans} là tập trường hợp được tạo ra từ mẫu gốc bằng biến đổi khác `raw`, khi đó:

$$\text{Robustness} = \frac{|\{r \in A_{\text{trans}} : f(r) = 1\}|}{|A_{\text{trans}}|}.$$

Coverage trong báo cáo **là recall trên tập chuỗi được gắn nhãn tấn công**, không phải tỷ lệ bao phủ CVE. Robustness đo khả năng phát hiện các biến thể biểu diễn **đã liệt kê**, không phải khả năng kháng mọi kỹ thuật né tránh. FPR trên tập hard-negative được cố ý làm khó, không tương đương FPR trong lưu lượng sản xuất theo tỷ lệ tự nhiên.

Các chỉ số phải được xuất đồng thời theo từng CWE, lớp biến đổi và tuyến xử lý. Một cổng phê duyệt **minh họa**, không phải tiêu chuẩn ngành, được định nghĩa: coverage ít nhất 90%; FPR không quá 5%; robustness ít nhất 85%. Cổng sử dụng logic AND; không lấy trung bình để một trục cao che giấu một trục thấp.

3.4. Quản trị vòng đời rule và vai trò LLM

Quy trình thay đổi rule gồm đề nghị có nguồn; kiểm tra trùng lặp, cú pháp và phạm vi; đánh giá trên tập tấn công và benign giữ lại; xét cổng ba trục; phê duyệt AppSec; triển khai canary có giới hạn; theo dõi drift; rollback khi tác động vượt ngưỡng. Với rule do LLM sinh, cần thêm ghi nhận model/version, prompt template, nhãn nguồn, phiên bản dữ liệu, người duyệt và bản diff rule trước/sau. Mỗi ứng viên nên có hạn xem xét lại để tránh tồn tại vô hạn không được bảo trì.

Các chức năng **Govern–Map–Measure–Manage** trong NIST AI RMF 1.0 tạo khung

tham chiếu phù hợp cho việc phân công trách nhiệm, hiểu phạm vi, đo tác động và xử lý rủi ro AI [9]. Trong ngữ cảnh WAF, NIST AI RMF không thay cho quy trình an toàn ứng dụng hoặc phê duyệt bảo mật; nó đóng vai trò bổ trợ khi sử dụng mô hình sinh.

4. Phương pháp thực nghiệm

4.1. Môi trường và thiết kế dữ liệu

Thực nghiệm chạy bằng **Python 3 tiêu chuẩn**, dùng các biểu thức chính quy và quy tắc xử lý chuỗi nội bộ. Không có máy chủ mục tiêu, ModSecurity, SafeLine, CRS vận hành thực tế, cơ sở dữ liệu, trình duyệt hoặc API LLM. Mã nguồn trong thư mục `src/`, kiểm thử đơn vị trong `tests/`, sổ rule trong `rules/` và đầu ra trong `results/`. Hạt giống định danh `20261016` được lưu để phục vụ truy vết phiên chạy; việc sinh mẫu hiện dùng vòng lặp xác định, không lấy số ngẫu nhiên.

Ba nhóm tấn công mô phỏng xuất phát từ năm dạng mẫu ban đầu cho mỗi CWE, mỗi dạng có mười chỉ số định danh. Mỗi trường hợp gốc tạo năm biểu diễn: `raw`, URL mã hóa một lần, URL mã hóa hai lần, đổi hoa/thường ASCII và một biến đổi theo CWE (comment trong SQL, HTML entity cho XSS, hoặc dấu phân cách đường dẫn). Quy tắc gắn nhãn dựa vào **nguồn sinh mẫu**, không có bộ máy kiểm chứng một payload còn khai thác được backend hay không. Đây là một hạn chế đặc biệt quan trọng đối với các phép biến đổi không bảo toàn ngữ nghĩa trên mọi môi trường.

Tập phát triển lấy các chỉ số 0–3, tập kiểm thử giữ lại lấy 4–9. Các mẫu gốc vẫn cùng họ giữa hai tập, nên sự phân tách này kiểm tra khả năng lặp lại theo định danh chứ **không** chứng minh tổng quát hóa sang ngữ pháp payload chưa thấy. Bộ benign gồm truy vấn tìm kiếm thông thường, bình luận, đường dẫn hợp lệ và ba loại hard-negative: tài liệu SQL có chuỗi giống chữ ký, ví dụ mã HTML trên tuyến bài hướng dẫn đã giả định escape, và đường dẫn `docs/../docs/...` vẫn ở trong phạm vi tài liệu.

Bảng 2. Quy mô dữ liệu tổng hợp và phân hoạch kiểm thử

Thành phần	Tập phát triển	Tập kiểm thử báo cáo	Ghi chú
Dấu hiệu tấn công, CWE-89	100	150	5 mẫu × 4 hoặc 6 định danh × 5 biểu diễn
Dấu hiệu tấn công, CWE-79	100	150	Gồm XSS token và HTML entity biến đổi
Dấu hiệu tấn công, CWE-22	100	150	Gồm biến đổi dấu phân cách đường dẫn
Hợp lệ: normal + hard-negative	60	120	Mỗi lớp bằng một nửa benign test

Thành phần	Tập phát triển	Tập kiểm thử báo cáo	Ghi chú
Tổng	**360**	**570**	Tập test cố định, không sửa kết quả thủ công

4.2. Quy trình đo và kiểm soát tái lập

Chạy `python src/wafbench.py --output results` từ thư mục gốc tạo `detailed_predictions.csv`, `summary.csv` và `metrics.json`. Chạy `python -m unittest discover -s tests -v` kiểm tra tính xác định của mẫu, giải mã hai cấp, chính sách đường dẫn, giả định tuyến hướng dẫn, comment SQL và việc không dùng đích mạng. Chạy `python src/audit_rules.py rules/rule_register.json` xác nhận các rule có trường truy vết bắt buộc. SHA-256 của tệp dự đoán được ghi trong JSON để đối chiếu kết quả.

Chúng tôi báo cáo khoảng Wilson 95% theo từng **trường hợp** như một mô tả thống kê phụ trợ. Vì nhiều mẫu dùng chung biểu thức nền và nhiều biểu diễn của cùng một mẫu, các trường hợp **không độc lập theo nghĩa thống kê**; không sử dụng khoảng này làm bằng chứng ý nghĩa thống kê hay khả năng tổng quát hóa ngoài dữ liệu mô phỏng. Một benchmark chính thức cần phân nhóm theo seed-template hoặc exploit family khi bootstrap và cần tập dữ liệu độc lập theo ứng dụng/CVE.

4.3. Kịch bản chuyển dịch biểu diễn (synthetic drift)

Để minh họa vì sao cần theo dõi thay đổi lưu lượng, tập tấn công test được chia thành **giai đoạn A** gồm dạng `raw` và thay đổi hoa/thường, và **giai đoạn B** gồm mã hóa URL và biến đổi theo CWE. Mỗi giai đoạn là một nhóm cố định trong **cùng bộ dữ liệu**, không phải lưu lượng quan sát theo thời gian. Chênh lệch recall vì vậy là thí nghiệm dịch chuyển cơ cấu kiểm thử, không phải ước lượng tỷ lệ drift thực tế.

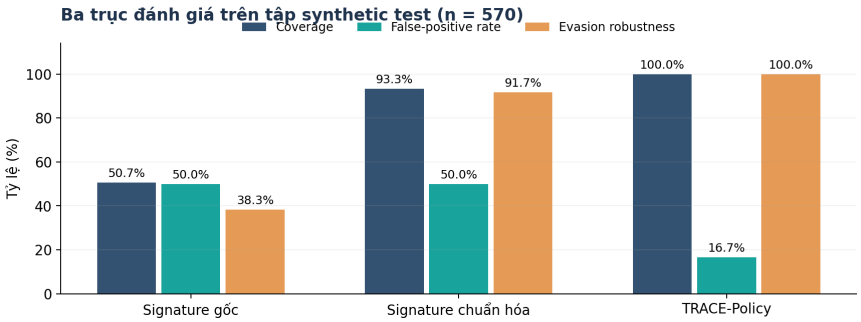
5. Kết quả

5.1. Đánh giá tổng hợp ba trục

Bảng 3. So sánh coverage, FPR và robustness của ba bộ mô phỏng

Phương án mô phỏng	TP / 450	FP / 120	Coverage	FPR	Robustness / 360
Raw signature	228	60	50,67%	50,00%	38,33%
Canonical signature	420	60	93,33%	50,00%	91,67%

Phương án mô phỏng	TP / 450	FP / 120	Coverage	FPR	Robustness / 360
TRACE-Policy	450	20	100,00%	16,67%	100,00%



Hình 2: Coverage, FPR và robustness trên 570 trường hợp test tổng hợp. Tỷ lệ FPR càng thấp càng tốt.

Giữa signature thô và signature sau chuẩn hóa, coverage tăng **42,66 điểm phần trăm** và robustness tăng **53,34 điểm phần trăm** nhưng FPR không giảm. TRACE-Policy cải thiện FPR thêm **33,33 điểm phần trăm** so với hai baseline, chủ yếu vì phân biệt ví dụ HTML hợp lệ ở tuyến hướng dẫn và chuẩn hóa đường dẫn trở về cùng gốc; tuy nhiên 20 trường hợp benign chứa tài liệu SQL vẫn bị chặn nhầm.

Để thể hiện độ bất định mô tả, các khoảng Wilson 95% theo trường hợp cho TRACE-Policy lần lượt là **[99,15%; 100,00%]** với coverage, **[11,06%; 24,35%]** với FPR và **[98,94%; 100,00%]** với robustness. Các khoảng này không xử lý sự phụ thuộc cùng họ mẫu, do đó không được diễn giải như kết quả sản xuất.

5.2. Phân rã theo nhóm CWE

Bảng 4. Kết quả theo nhóm CWE trên tập kiểm thử

CWE	Coverage raw	Coverage sau chuẩn hóa	Coverage TRACE	FPR TRACE
CWE-89 / SQLi	40,00%	80,00%	100,00%	50,00%
CWE-79 / XSS	52,00%	100,00%	100,00%	0,00%
CWE-22 / Path traversal	60,00%	100,00%	100,00%	0,00%

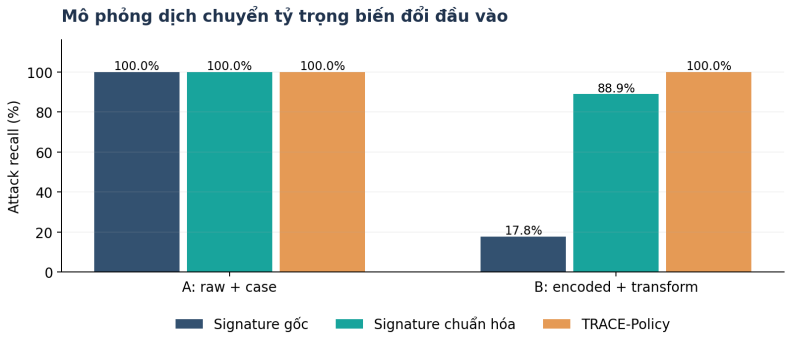
Chênh lệch giữa các CWE cho thấy một tỷ lệ tổng hợp có thể che giấu loại lỗi đặc biệt khó. Ở mô phỏng này, chuẩn hóa chuỗi vẫn bỏ sót 30 mẫu SQLi comment-separated;

TRACE-Policy bổ sung bước xử lý comment nên không bỏ sót các mẫu thuộc họ đã tạo. Ngược lại, việc chặn tài liệu SQL có các cụm `UNION SELECT` trong nội dung tìm kiếm tạo ra 20 false positive. Không nên thêm ngoại lệ theo chính văn bản do người dùng gửi để giải quyết nhanh, bởi điều đó có thể biến dữ liệu người dùng thành tín hiệu bỏ qua bảo vệ. Cần kiểm chứng ngữ cảnh xử lý thực và phân tách trường dữ liệu qua kênh tin cậy.

5.3. Thử nghiệm synthetic drift

Bảng 5. Đánh giá khả năng phát hiện theo nhóm biểu diễn đầu vào

Hỗn hợp đầu vào tấn công	Số mẫu	Raw signature	Canonical signature	TRACE-Policy
A: raw và thay đổi hoa/thường	180	100,00%	100,00%	100,00%
B: URL encoding và biến đổi theo CWE	270	17,78%	88,89%	100,00%



Hình 3: Suy giảm recall khi cơ cấu test chuyển từ nhóm biểu diễn đơn giản sang nhóm đã biến đổi.

Khi chuyển sang nhóm biến đổi B, raw signature giảm **82,22 điểm phần trăm** so với A. Kết quả hỗ trợ yêu cầu đo robustness tách biệt khỏi coverage trung bình và đặt tín hiệu giám sát thay đổi tỷ trọng biến đổi. Tuy nhiên một hệ thống triển khai phải phân biệt drift hợp lệ do thay đổi client với hành vi né tránh, đồng thời xét false positive trước khi tự cập nhật luật.

5.4. Quyết định qua cổng phê duyệt

Không phương án nào thỏa đồng thời điều kiện coverage $\geq 90\%$, FPR $\leq 5\%$ và robustness $\geq 85\%$ trên tập test này. Raw signature không đạt coverage và robustness; canonical signature không đạt FPR; TRACE-Policy **không đạt FPR**, mặc dù đạt hai điều kiện còn lại. Quyết định quản trị đúng là **không tự động đưa bất cứ phương án nào vào sản xuất** dựa trên thí nghiệm này. Điều kiện FPR 5% chỉ là ngưỡng minh họa của nghiên cứu; tổ chức vận hành cần định nghĩa mức độ chịu rủi ro theo tác động kinh doanh và phân bố lưu lượng thực.

6. Bàn luận về chính sách và quản trị an ninh mạng

6.1. Vì sao kết quả phát hiện cao chưa đủ để triển khai

Trong tập thử, TRACE-Policy chặn tất cả 450 mẫu dấu hiệu tấn công nhưng đồng thời chặn 20/120 mẫu hợp lệ. Nếu chỉ trình bày attack recall 100%, người quản trị có thể đánh giá sai tác động tới người dùng. FPR được đo trên các hard-negative cố tình xuất hiện dày đặc, do đó không suy diễn rằng 16,67% request hợp lệ ngoài sản xuất sẽ bị chặn. Đồng thời, chỉ số **0 FN** trong một không gian biến đổi hẹp cũng không chứng minh tồn tại phòng thủ hoàn hảo.

Một triển khai thực cần thu thập lưu lượng benign theo nhiều mùa, phân tích nhóm đường dẫn, loại người dùng, thời điểm cao điểm, khả năng hợp lệ hóa backend và trường dữ liệu được phép chứa code. Quyết định canary nên dựa vào số request bị chặn, tác động giao dịch, dấu vết rule match và mức ưu tiên ứng dụng. Luật sinh tự động chỉ nên bắt đầu ở chế độ phát hiện hoặc shadow, có người phê duyệt trước khi block.

6.2. Sổ luật có bằng chứng và kiểm toán

`rules/rule_register.json` chứa ba mục `TW-001` đến `TW-003`, tương ứng CWE-89, CWE-79 và CWE-22. Mỗi mục có nguồn CWE, tuyến áp dụng, mô tả chính sách, chủ sở hữu cần được chỉ định, trạng thái `prototype_only`, hướng dẫn rollback và hạn xem xét lại 30 ngày. Mục này mới là **sổ chứng cứ kỹ thuật ở cấp CWE**, chưa có ánh xạ CVE cụ thể đã được xác thực. Nếu sau này thêm CVE, hồ sơ phải chứa phiên bản sản phẩm, phiên bản lỗ hổng, bước tái tạo trên môi trường kiểm soát và mẫu đối chứng âm.

Bảng 6. Kiểm soát quản trị trước khi phê duyệt luật WAF

Điểm kiểm soát	Bằng chứng tối thiểu	Vai trò quyết định
Nguồn gốc	CWE, CVE nếu đã xác minh, phiên bản dữ liệu và rule	Nghiên cứu / Threat Intel
Hợp lệ kỹ thuật	Kiểm thử cú pháp, route, backend semantics	AppSec / Application Owner

Điểm kiểm soát	Bằng chứng tối thiểu	Vai trò quyết định
Rủi ro người dùng	FPR theo endpoint, canary và rollback	Product Owner / SRE
Triển khai	Biên bản duyệt, phiên bản, TTL, log thay đổi	Security Change Manager
LLM (nếu sử dụng)	Model version, prompt, filter, người review	AI Governance / AppSec

6.3. Chính sách tự thích nghi theo drift

Drift nên được hiểu theo nhiều nguồn: (i) tỷ trọng kiểu mã hóa/định dạng đầu vào; (ii) phân bố endpoint và tham số; (iii) tỷ lệ match theo rule; (iv) xác nhận chặn nhầm từ đội vận hành; (v) thay đổi backend hoặc bản vá. Có thể đặt cảnh báo khi robustness trên một bộ regression cố định suy giảm từ ngưỡng cổng, song không được tự động tăng paranoia level hoặc chặn rộng chỉ vì thấy chuỗi lạ. Thiết kế phù hợp là **observe → triage → propose → offline validation → approve → canary → rollback if needed**.

6.4. An toàn dữ liệu và an toàn của LLM

Khi tích hợp LLM, nội dung log HTTP có thể chứa PII, token hoặc dữ liệu kinh doanh; cần loại bỏ hoặc thay thế định danh trước khi sử dụng và hạn chế lưu giữ theo chính sách tổ chức. Prompt chứa các mẫu HTTP từ bên ngoài là dữ liệu không tin cậy; không trao quyền để LLM tự sửa luật hoặc gửi lưu lượng vào mục tiêu không được cấp phép. Luật đề xuất phải qua kiểm tra độc lập để hạn chế overblocking, rule shadowing, parser differential và phụ thuộc vào câu trả lời sinh thiếu bằng chứng. Đặc biệt không dùng cụm từ “bảo vệ CVE” nếu chỉ đã kiểm tra các chuỗi liên quan CWE.

7. Hạn chế và đe dọa đối với tính hợp lệ

Tính hợp lệ cấu trúc: Mẫu được gắn nhãn bằng nguồn sinh, không bằng kết quả thực thi trên ứng dụng có lỗ hổng. Một chuỗi bị đánh dấu là dấu hiệu tấn công không đồng nghĩa nó thực sự gây khai thác trong bất cứ backend nào. Biến đổi HTML entity hoặc dấu gạch ngược phụ thuộc parser và nền tảng.

Tính hợp lệ nội tại: Các quy tắc được viết bằng tay cùng không gian mẫu đơn giản; tham số hóa bằng số không tạo ra payload family độc lập. Tỷ lệ phát hiện 100% của TRACE-Policy vì vậy dễ bị lạc quan; chính sách `/api/tutorial` có giả định xuất HTML đã escape, chưa được thực nghiệm backend xác nhận. Thử nghiệm không chứng minh lợi ích của LLM hay khả năng sinh rule bằng LLM.

Tính hợp lệ bên ngoài: Không có WAF thương mại, OWASP CRS chạy thật, kiểm chứng CVE, HTTP normalization stack hay lưu lượng hợp lệ thực. Không có đối chiếu latency, chi phí tính toán, throughput, rule conflict hoặc tỷ lệ base-rate trong sản xuất. Không thể so sánh định lượng kết quả này với DEG-WAF, GenSQLi hay Miggo.

Tính hợp lệ thống kê: Có 570 case test nhưng chỉ một số ít họ mẫu; các biến thể phụ thuộc cùng nguồn nên khoảng Wilson và số lượng quan sát không phản ánh số đơn vị độc lập. Thiết kế mở rộng phải tách biệt theo họ khai thác, CVE/ứng dụng, thời gian, nhãn xác thực và báo cáo sai số theo cụm.

8. Hướng phát triển và kế hoạch nghiên cứu tiếp theo

Giai đoạn 1 là tích hợp **WAF thực trong lab được cấp phép**, ưu tiên ModSecurity với phiên bản OWASP CRS được ghim; mô hình hóa luồng HTTP và ghi đầy đủ cả request–response để xác thực semantics. Giai đoạn 2 bổ sung benign traffic có đồng ý và dữ liệu độc lập theo ứng dụng; tạo phép thử CVE đã có môi trường tái lập để liên kết CWE–CVE thực chứng. Giai đoạn 3 mới thêm **LLM sinh ứng viên** ở chế độ offline, so sánh với generator không dùng LLM trên cùng ngân sách, mẫu và tiêu chuẩn đánh giá. Giai đoạn 4 đo đường cong trade-off theo threshold, độ trễ, thời gian duyệt, tỷ lệ rollback và khả năng drift.

Tiêu chí để kết luận một đề xuất LLM tốt hơn heuristic phải gồm (1) mức tăng ba chỉ số trên tập độc lập, (2) tỷ lệ mẫu sinh thực sự hợp lệ với backend, (3) chi phí và độ trễ sinh/tuning, (4) khả năng giải thích–truy vết, (5) ảnh hưởng vận hành khi áp dụng vào quy trình có người phê duyệt. Không có những đối chứng này thì chỉ có thể gọi đó là **đề xuất kiến trúc**.

9. Kết luận

Bài nghiên cứu đề xuất TRACE-WAF như một cách nối kết hai mục tiêu thường bị tách rời: đánh giá an toàn kỹ thuật của luật WAF và quản trị vòng đời rule có nguồn truy vết. Nguyên mẫu offline cung cấp kết quả tái lập cho ba trục coverage, FPR và robustness trên dữ liệu tổng hợp của SQLi, XSS và path traversal. Chuẩn hóa và chính sách theo tuyến cải thiện việc phát hiện các mẫu biến đổi trong tập đã tạo, nhưng FPR của phương án tốt nhất vẫn **16,67%**, cao hơn ngưỡng 5% minh họa. Đây là kết quả quan trọng của góc nhìn quản trị: **không phê duyệt triển khai chỉ vì tỷ lệ chặn cao**. Các bước tiếp theo bắt buộc gồm kiểm tra backend và WAF thực có phép, kiểm định độc lập theo CVE, thí nghiệm LLM có đối chứng và canary/rollback có người chịu trách nhiệm.

Tài liệu tham khảo

[1] OWASP Foundation. *OWASP Core Rule Set (CRS)*. https://owasp.org/projects/crs/ (truy cập 16/10/2026).

[2] OWASP CRS Project. *CRS Documentation: Anomaly Scoring, Paranoia Levels, False Positives and Tuning*. https://coreruleset.org/docs/index.print (truy cập 16/10/2026).

[3] Miggo Security. *Beat the Bypass: A Benchmark Study of WAF Weaknesses and AI Mitigation*, thông cáo và báo cáo công bố 17/12/2025. https://www.miggo.io/reports-webinar/benchmark-study-of-waf-weakness-and-ai-mitigation (truy cập 16/10/2026).

[4] T. G. Bao, D. C. Duc, và P. T. Duy. *Generating evasive payloads for assessing Web Application Firewalls with Reinforcement Learning and Pre-trained Language Models*. Journal of Science and Technology on Information Security, 2025. DOI: https://doi.org/10.54654/isj.v2i25.1128.

[5] V. Babaey và A. Ravindran. *GenSQLi: A Generative Artificial Intelligence Framework for Automatically Securing Web Application Firewalls Against Structured Query Language Injection Attacks*. Future Internet, 17(1), 8, 2025. DOI: https://doi.org/10.3390/fi17010008.

[6] MITRE. *CWE-89: Improper Neutralization of Special Elements used in an SQL Command*. https://cwe.mitre.org/data/definitions/89.html (truy cập 16/10/2026).

[7] MITRE. *CWE-79: Improper Neutralization of Input During Web Page Generation*. https://cwe.mitre.org/data/definitions/79.html (truy cập 16/10/2026).

[8] MITRE. *CWE-22: Improper Limitation of a Pathname to a Restricted Directory*. https://cwe.mitre.org/data/definitions/22.html (truy cập 16/10/2026).

[9] E. Tabassi, NIST. *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*, NIST AI 100-1, 2023. DOI: https://doi.org/10.6028/NIST.AI.100-1.

Phụ lục A. Hướng dẫn chạy và đối chiếu kết quả

Yêu cầu Python từ 3.10, không cần kết nối Internet. Tại thư mục chứa tài liệu và mã nguồn, thực hiện:

```
python src/wafbench.py --output results
python -m unittest discover -s tests -v
python src/audit_rules.py rules/rule_register.json
```

Đầu ra gồm `results/detailed_predictions.csv` (570 mẫu), `results/summary.csv` (12 dòng) và `results/metrics.json` (cấu hình, SHA-256, ma trận nhầm lẫn và synthetic drift). Tái tạo biểu đồ bằng `python src/plot_results.py` (cần matplotlib). SHA-256 của `detailed_predictions.csv` trong lần chạy này: `4f50ab19c6679411fb9702eb7d2c28f8423aa45fe8e5366cb41283723ec3be86`. Nếu hash khác, phải kiểm tra mã và dữ liệu trước khi sử dụng kết quả.